[Active Directory & Kerberos Fundamentals Notes]

[1. Introduction to Windows Active Directory]

[What is Active Directory (AD)?]

- Think of Active Directory (AD) as the **"Brain"** or **"Manager"** of a company's computer network.
- In a small home, you might have one laptop where you log in with your own password. But in a big company with 5,000 employees and 5,000 laptops, you cannot manually create an account for every person on every single laptop.
- AD solves this by creating a centralized phonebook where everyone's identity is stored once, allowing them to use it to log into any computer in the company.

[The Core Concept: Identity & Access]

At its heart, AD performs two essential functions:

1. **Authentication:** Verifying you are who you say you are (e.g., *"Yes, this is John Doe's correct password"*).
2. **Authorization:** Checking if you are allowed to perform a specific action (e.g., *"John is allowed to use the HR printer, but NOT allowed to open the Finance folder"*).

[2. Active Directory Hierarchy & Ecosystem]

[Architectural Layout Diagram]

```
+---------------------------------------+
|        FOREST & TREES (Big Picture)   |
|  Highest container. A collection of   |
|  domain trees that trust each other.  |
+-------------------+-------------------+
                    |
                    v
+---------------------------------------+
|        DOMAINS (Security Boundary)    |
|  A central, defined database holding  |
|  its own accounts, objects, & policies|
+-------------------+-------------------+
                    |
                    v
+---------------------------------------+
|    ORGANIZATIONAL UNITS (OUs)         |
|  Logical folders (e.g., Sales, HR)    |
|  to group objects for easy management |
+-------------------+-------------------+
                    |
                    v
+---------------------------------------+
|       OBJECTS (Building Blocks)       |
|  Single entries in the directory:     |
|  [ User ]  [ Computer ]  [ Printer ]  |
+---------------------------------------+
```

[How Components Work Together]

[Structural Components Explained]

[Zone 1: Hierarchy & Physical Structure]

- **Objects:** The smallest unit. An object is a distinct "thing" within the network.
  - *Users:* Identities and profiles of people who log in.
  - *Computers:* Machine accounts used for workstations and servers to gain network access.
  - *Printers/Shared Folders:* Shared network resources that users need to access.
  - *Groups:* Collections of users, devices, or computers compiled for simplified permissioning.
- **Organizational Units (OUs):** Logical folders used to organize objects. Administrators create OUs (like "Accounting Dept" or "Sales Team") to easily apply specific policies or delegate permissions.
- **Domains:** The primary security boundary containing a central database of objects and policies. It represents self-contained administration and usually looks like a website address (e.g., corp.example.com).
- **Tree:** A single namespace of connected domains sharing a common root (e.g., uk.corp.net and us.corp.net).
- **Forest:** The highest container and ultimate security boundary. It is the complete eco-system connecting unrelated domain trees through transitive trust relationships. *(Example: If Company A buys Company B, they can sync their individual trees under one Forest so they can talk to each other).*

[Zone 2: Physical Components]

- **Domain Controller (DC):** The actual server hardware running the Active Directory software. It holds the physical AD database file (called ntds.dit). When a user enters a password, the workstation queries the DC to verify it.
- **Sites:** Physical network locations (like a branch office in London and another in New York). AD uses sites to ensure a user in London authenticates against a local London server instead of waiting for a slow signal from New York.

[Active Directory Components Analogy Summary]

AD Component	Simple Analogy
Object	A single contact entry saved in your phone.
OU (Organizational Unit)	A specific folder category in your contacts list (e.g., "Work Contacts").
Domain	Your entire phone's contact list directory.
Forest	Multiple separate phones synced together to share data.
Domain Controller	The actual physical phone hardware storing the contact database.

[3. Core Network Languages & Protocols]

Active Directory relies on three primary protocols to function across the network:

1. **DNS (Domain Name System):** The network's "GPS." It translates domain names and helps computers find exactly where the Domain Controller resides on the network.
2. **LDAP (Lightweight Directory Access Protocol):** The "search language." It is used to look up and retrieve information within the AD database (e.g., finding a user's email address or group membership).
3. **Kerberos:** The "ticket system." A secure authentication protocol that issues digital tokens so users do not have to re-type their passwords every time they access a new network resource.

[Group Policy Objects (GPOs) - "The Boss Mode"]

- Group Policy sets management rulebooks for all objects at the OU, Domain, or Site level.
- It allows an IT administrator to configure settings—such as corporate desktop wallpapers, complex password policies, or automatic 5-minute inactivity screen locks—for thousands of computers simultaneously with a single click.

[4. Kerberos Deep Dive]

[Key Terms & Players]

- **The Client (You):** The user machine trying to log in and use resources.
- **The Key Distribution Center (KDC / Domain Controller):** The "Ticket Office" that manages passwords and authentications.
  - **AS (Authentication Service):** The specific component that issues the entry pass (TGT).
  - **TGS (Ticket Granting Service):** The component that hands out individual ride tickets (Service Tickets).
- **The Resource Server (The Ride):** The file share, folder, or printer you want to use.

[Core Concepts: TGT vs. Session Key]

[1. Ticket Granting Ticket (TGT)]

- **Analogy:** A "Master Wristband" obtained at the front gate of a theme park.
- **What it is:** Your master proof of identity showing you are securely logged in.
- **Contents:** Contains your User ID, IP Address, a timestamp, and an expiration limit (typically 10 hours).
- **The Security:** It is encrypted by the KDC using a secret key known only to the Domain Controller. Because it is sealed, the client cannot read or tamper with it. When presented back to the DC, the DC decrypts it to verify the user's legitimacy.

[2. Session Key]

- **Analogy:** A temporary "Secret Handshake."
- **What it is:** A unique, temporary, and disposable password generated for a single secure conversation segment.
- **Contents:** Random strings of data (e.g., 1aBc2D × YZ9).
- **The Purpose:** To protect communication traffic from network eavesdroppers without exposing the user's real master password. The DC sends a copy to both the client and the target server so they can build an encrypted channel for private messages.

[The "Two Envelope" Response Trick]

When you log in, the Domain Controller returns its authentication response in two distinct envelopes:

- **Envelope A (The TGT):** This is locked by the DC. You cannot open it. You simply hold onto it to show the network security guards later.
- **Envelope B (The Session Key):** This is locked using a key derived from your user password. Because you know your password, your machine decrypts it and retrieves the Session Key inside.

> **Common Misconception:** The TGT does *not* grant you direct access to network folders or files. The TGT only permits you to talk to the TGS (Ticket Office) to request specific **Service Tickets** for individual resources.

[Summary Comparison Table]

Feature	TGT (The Wristband)	Session Key (The Secret Handshake)
Who makes it?	The Domain Controller (KDC).	The Domain Controller (KDC).
Who can read it?	Only the Domain Controller.	Both You and the target Resource Server.
Purpose	To prove you are already authenticated.	To encrypt data and prevent eavesdropping.
Lifespan	Usually lasts 10 hours.	Very short (often expires when the task is done).

[5. The 6-Step Kerberos Authentication Process]

```
[ Client ] ------------ (1) Request TGT -------------> [ Domain Controller ]
[ Client ] <------- (2) TGT + Session Key ------------ [   (KDC = AS + TGS)   ]
|
+------------------ (3) Request Ticket + Auth --------> [ Domain Controller ]
[ Client ] <------- (4) Ticket + Session Key --------- [   (KDC = AS + TGS)   ]
|
+------------------ (5) Request Service + Auth ------> [ Resource Server ]
[ Client ] <------- (6) Server Authentication -------- [ Resource Server ]
```

[Detailed Phase Breakdown]

[Phase 1: Getting your "Entry Pass" (Steps 1 & 2)]

- **Step 1 (Request TGT):** You type in your user credentials. Your machine contacts the Authentication Service (AS) at the KDC stating, *"Hey, I'm John. Here is encrypted proof of my identity."*
- **Step 2 (TGT + Session Key):** The AS validates your existence against the database. If valid, it returns a TGT (the wristband pass) and a Session Key. This proves you have paid to enter the park but does not let you ride anything yet.

[Phase 2: Getting your "Ride Ticket" (Steps 3 & 4)]

- **Step 3 (Request Ticket + Auth):** You decide you need to open a shared resource, like a "Finance Spreadsheet" (The Ride). You send your TGT wristband to the Ticket Granting Service (TGS) and say, *"I would like to access the Finance server, please."*
- **Step 4 (Ticket + Session Key):** The TGS verifies your wristband and checks your permissions. If authorized, it generates a specific **Service Ticket** unique to that resource and hands it to you.

[Phase 3: Enjoying the Ride (Steps 5 & 6)]

- **Step 5 (Request Service + Auth):** You present the specific Service Ticket directly to the Resource Server.
- **Step 6 (Server Authentication):** The Resource Server reads the ticket, recognizes the KDC's official digital signature, grants access, and says, *"Welcome aboard!"* You can now read or modify your files.

[Why is this Framework Used?]

- **Security:** Your actual plaintext password is only transmitted across the wire once during initial boot/login. After that, only temporary cryptographic tickets cross the network. Attackers listening in cannot steal your password.
- **Speed & Convenience:** Once your machine holds the initial TGT (Step 2), you do not have to type your password again for the rest of the day, even if you access 50 different printers, databases, or servers.

[6. Active Directory Attacks & SOC Operations]

[Common Active Directory Attacks]

1. **Pass-the-Hash:** Attackers bypass typing plain passwords by harvesting and using the pre-computed NTLM cryptographic hash directly to authenticate.
2. **Kerberoasting:** Attackers steal valid Kerberos service tickets from memory and crack them offline to recover service account passwords.
3. **Golden Ticket:** A catastrophic attack where threat actors compromise the AD master key (krbtgt) to forge completely custom Kerberos TGT tickets, giving them indefinite administrative access.
4. **DCSync:** Attackers pretend to be a legitimate Domain Controller to request password hashes directly from the main directory database.
5. **Privilege Escalation:** Exploiting misconfigurations to force unauthorized additions of low-tier user accounts directly into high-tier groups like **Domain Admins**.

[Crucial AD Security Log Event IDs]

Event ID	Security Meaning & Significance
4624	Successful User Login.
4625	Failed Login Attempt (Useful for tracking brute force/password spraying).
4672	Admin/Special Privileges Assigned during logon.
4720	A brand new user account was created.
4732	A user account was explicitly added to a security group.

Final SOC Analyst Mindset: When investigating anomalous actions inside Active Directory, look past simple technical readouts. Don't just ask: *"What command ran?"*
Always Ask: Why was it run? Who executed it? What resources did it access? Did it attempt to move laterally across the domain?